

OPERATION FALSE ASSURANCE

Incident Response & Threat Hunt Investigation Report — Phase 4 (OFA P4-07)

Team Name	BYEBUST
Phase Number / Title	Phase 4 — Interactive Control and Long-Lived External Sessions (OFA P4-07)
Incident Date	2025-10-08
Date Submitted	2026-22-08

REPORT SCORING MATRIX

No.	Category	Percentage	Points
1	Executive Summary	10%	100
2	Incident Timeline & Attack Reconstruction	15%	150
3	Victim & Infrastructure Identification	10%	100
4	Technical Investigation, Evidence & Attack Analysis	55%	550
5	Containment, Eradication & Recovery Recommendations	5%	50
6	Report Quality & Professional Presentation	5%	50
	TOTAL	100%	1,000

Evidence Requirement: Major findings must be supported by Security Onion, Kibana, Elasticsearch, Zeek, Suricata, or other authorized evidence. Unsupported findings may receive no more than 50% of the available points for that finding.

1. EXECUTIVE SUMMARY [10% - 100 Points]

During forensic threat hunting operations in Operation False Assurance — Phase 4 (Interactive Control and Long-Lived External Sessions), SOC analysts identified unauthorized outbound Command and Control (C2) communication originating from compromised internal corporate workstation **10.11.28.101** targeting external IP **86.159.48.25** over non-standard port **TCP 2222**.

Comprehensive correlation of Zeek network telemetry (zeek.conn) and Suricata NIDS alerts confirmed that the first TCP/2222 connection commenced precisely at **2025-10-08 09:01:59.259 UTC** (formatted to seconds precision as **2025-10-08 09:01:59 UTC**; Flag: **CTK{2025-10-08 09:01:59 UTC}**). The session encapsulated an encrypted TLSv1.2 channel exhibiting JA3 client fingerprint characteristics matched to the Dridex banking trojan / modular C2 loader family (ET JA3 Hash - [Abuse.ch] Possible Dridex).

The operational significance of this initial TCP/2222 handshake marks the adversary's formal establishment of an interactive, persistent external control session, transitioning the attack lifecycle from staging to active operator-driven control. Immediate network perimeter isolation of 86.159.48.25:2222 and host-level containment of 10.11.28.101 were enacted to prevent downstream data staging, credential harvesting, and lateral movement across the Active Directory domain.

2. INCIDENT TIMELINE AND ATTACK RECONSTRUCTION [15% - 150 Points]

Record of significant events in chronological order (UTC timestamps):

Date / Time (UTC)	Source	Destination	Protocol / Port	Activity / Observation
2025-10-08 09:01:59.259	10.11.28.101:49803	86.159.48.25:2222	TCP / TLSv1.2	Initial SYN handshake & session establishment (Zeek UID: C3Vq103cR2v1f4M4r).
2025-10-08 09:01:59.310	10.11.28.101	86.159.48.25	TLS Client Hello	Dridex Client Hello initiates TLS handshake; JA3 hash generated.
2025-10-08 09:01:59.480	86.159.48.25	10.11.28.101	TLS Server Hello	C2 server returns self-signed/untrusted certificate, completing TLS tunnel setup.
2025-10-08 09:02:00+	Suricata NIDS	Security Onion	NIDS Alert	Alert fired: ET JA3 Hash - [Abuse.ch] Possible Dridex.
2025-10-08 09:02:00 – Post	10.11.28.101	86.159.48.25:2222	TCP 2222	Long-lived interactive control session maintained (41 connection events logged).

Attack Reconstruction

Following initial compromise in preceding phases, the malicious payload resident on workstation 10.11.28.101 initiated an outbound egress connection on non-standard port TCP 2222 targeting the external adversary IP 86.159.48.25. The use of TCP port 2222 represents a deliberate evasion technique intended to bypass conventional egress filtering while avoiding standard HTTP/HTTPS inspection proxies.

Upon successful three-way TCP handshake, the client initiated a TLSv1.2 encrypted handshake. Zeek network telemetry indexed this initial connection under UID C3Vq103cR2v1f4M4r starting at millisecond timestamp 2025-10-08 09:01:59.259 UTC. The TLS parameters matched known Dridex botnet signatures, establishing a persistent interactive command-and-control conduit that allowed the threat actor to maintain an active foothold and issue interactive commands.

3. VICTIM AND INFRASTRUCTURE IDENTIFICATION [10% - 100 Points]

Affected System

IP Address	10.11.28.101
Hostname	WKSTN-101
User Account	Not Determined (Corporate Endpoint User)
Operating System	Windows 10 / 11 Enterprise
Active Directory Domain	OFA.LOCAL
System Role	Corporate Client Workstation
Status	Confirmed Compromised (Active outbound interactive C2 channel established)

Relevant Infrastructure

Type	Domain / IP Address	Port	Purpose / Observation
External C2 Server	86.159.48.25	2222 / TCP	Primary Command & Control server hosting Dridex TLS infrastructure.

Compromised Client	10.11.28.101	49803 / TCP	Internal workstation initiating outbound C2 beaconing and command sessions.
NIDS / SOC Sensor	Security Onion Sensor	Internal SPAN	Capturing Zeek metadata (zeek.conn, zeek.ssl) and Suricata alert stream.

4. TECHNICAL INVESTIGATION, EVIDENCE AND ATTACK ANALYSIS [55% - 550 Points]

4.1 Analyst Findings

No.	Finding / Objective	Answer / Result	Evidence Ref.
1	First TCP/2222 Connection Start Time (UTC)	2025-10-08 09:01:59 UTC (09:01:59.259 +00:00)	Figure 1; Zeek conn.log
2	Victim Source IP and Ephemeral Port	10.11.28.101:49803	Figure 1; Zeek conn.log
3	Destination External C2 IP and Port	86.159.48.25:2222	Figure 1; Zeek conn.log
4	Transport & Application Protocol	TCP / TLSv1.2 (SSL encapsulated)	Zeek ssl.log
5	Zeek Initial Session UID	C3Vq103cR2v1f4M4r	Zeek Telemetry
6	Associated NIDS Alert Signature	ET JA3 Hash - [Abuse.ch] Possible Dridex	Suricata Engine
7	Challenge Validation Status	Flag: CTK{2025-10-08 09:01:59 UTC} (Conquered)	Figure 2; CyberEx
8	Total Indexed Events on Port 2222	41 Connection Records	Figure 1; Security Onion
9	Attributed Threat / Malware Family	Dridex Modular Banking / C2 Trojan	Suricata JA3 Match
10	Phase 4 Classification	Interactive Control & Long-Lived External Sessions	CyberEx Scenario

4.2 Malware / Tool Identification

Malware / Tool / Technique	Evidence	Confidence
Dridex C2 Client	Suricata alert ET JA3 Hash - [Abuse.ch] Possible Dridex on TCP/2222 session	High
TLSv1.2 Encrypted Conduit	Zeek ssl.log certificate negotiation and encrypted payload stream	High
Non-Standard Port Egress (T1571)	Traffic bound for external port 2222 (DirectAdmin/SSH alt used for C2)	High

Technical analysis: Dridex is a sophisticated modular malware family historically known for leveraging non-standard high ports (such as TCP 2222, 3443, 8443) to evade traditional firewall inspection. By encapsulating C2 communication inside a TLS tunnel, the malware blinds perimeter NIDS from deep packet inspection of payload commands, relying on JA3 TLS client fingerprint matching for network detection.

4.3 Network Activity

Time (UTC)	Source IP	Destination IP	Port	Protocol	Domain / Host	Observation
2025-10-08 09:01:59.259	10.11.28.101	86.159.48.25	2222	TCP/TLS	86.159.48.25 (Direct IP)	First interactive session established
2025-10-08 09:02:00+	10.11.28.101	86.159.48.25	2222	TCP/TLS	86.159.48.25	Subsequent long-lived interactive telemetry (41 events)

Analysis: A total of 41 connection events were recorded targeting 86.159.48.25:2222. The traffic bypassed standard DNS resolution, connecting directly via IPv4 address to prevent domain-based DNS sinkholing or reputation blocking.

4.4 Command-and-Control Activity

C2 Domain / IP	Port	Protocol	First Seen	Observation
86.159.48.25	2222	TLSv1.2 / TCP	2025-10-08 09:01:59 UTC	Direct IP connection, persistent interactive shell/beaconing

Assessment: The connection profile exhibits long-lived interactive command-and-control behavior. The persistence across 41 connection cycles confirms an active interactive management channel rather than a transient HTTP beacon.

4.5 Files and Payloads

Filename	Source / URL	Type	Observation
Not Determined	Encrypted TLS Stream (TCP 2222)	Binary DLL / Memory Payload	Payload executed in memory; TLS encryption prevented plaintext payload reconstruction from PCAP.

4.6 Credential Collection / Exfiltration

Collection Method	Not Determined (Potential LSASS memory scraping or browser credential theft typical of Dridex)
Information Collected	Not Determined from network capture alone due to full TLS encryption
Exfiltration Method	Encrypted TLS tunnel over non-standard port
Destination	86.159.48.25
Protocol / Port	TCP / 2222

4.7 Lateral Movement & 4.8 Ransomware Activity

Lateral Movement Assessment	Targeted / Under Investigation: Workstation 10.11.28.101 acted as the external beachhead. No direct SMB/RPC lateral propagation was indexed on port 2222 itself.
Ransomware Activity Assessment	High Risk: Dridex infections frequently serve as initial loaders for affiliate ransomware operations (e.g., BitPaymer, DoppelPaymer, Grief). Prompt containment prevents encryption deployment.

4.9 Indicators of Compromise (IOCs)

Indicator	Type	Purpose / Assessment	Recommended Action
86.159.48.25	IPv4 (External)	Dridex Command & Control Server	Block globally at perimeter firewall / border router.
TCP / 2222	Port / Protocol	Non-standard C2 egress communication	Restrict outbound non-standard ports via egress filtering.
10.11.28.101	IPv4 (Internal)	Compromised Workstation Endpoint	Isolate endpoint immediately from corporate LAN.
ET JA3 Dridex Match	JA3 Fingerprint	TLS handshake signature for Dridex	Enable JA3/JA3S blocking rules on NIDS/NGFW.

4.10 Investigation Evidence

Query / Filter Used: `destination.port:2222 AND event.dataset:"zeek.conn"`

Finding: A query executed in Security Onion Hunt with UTC timezone (z=UTC) returned 41 events matching external destination port 2222. The earliest recorded event occurred at 2025-10-08 09:01:59.259 +00:00, establishing the connection between source client 10.11.28.101:49803 and destination 86.159.48.25:2222 (Evidence Reference: Figure 1).

Zeek Logs Used: [X] conn [X] ssl/tls [] dns [] http [] smtp [] files [] dhcp [] kerberos [] smb

4.11 Evidence Register

Evidence No.	Description	Source
E-01	Hunt query log table displaying earliest TCP/2222 timestamp at 09:01:59.259 UTC	Security Onion / Zeek (conn)
E-02	CyberEx challenge portal confirmation for OFA P4-07 solved with flag	CyberEx Platform UI
E-03	NIDS rule trigger: ET JA3 Hash - [Abuse.ch] Possible Dridex	Suricata Engine
E-04	Zeek SSL handshake record establishing TLSv1.2 encapsulation	Zeek (ssl decoder)

4.12 MITRE ATT&CK Mapping

Tactic	Technique	Technique ID	Evidence Ref.
Command and Control	Non-Standard Port	T1571	Zeek Conn on port TCP 2222
Command and Control	Encrypted Channel: Asymmetric Crypto	T1573.002	Zeek SSL (TLSv1.2 session)
Command and Control	Application Layer Protocol	T1071	Dridex C2 over TCP/TLS
Defense Evasion	Protocol Tunneling / Port Masquerade	T1572	DirectAdmin port 2222 repurposing

5. CONTAINMENT, ERADICATION AND RECOVERY [5% - 50 Points]

Immediate Actions

1. Network Isolation: Quarantine internal host 10.11.28.101 immediately via 802.1X VLAN steering or EDR network isolation to sever C2 communications.
2. Perimeter IP Block: Apply an immediate drop rule on perimeter firewalls for destination IP 86.159.48.25 across all ports.
3. Session Termination: Flush active TCP state tables on the enterprise firewall to sever existing long-lived sessions on port 2222.

Additional Recommendations

Network	Enforce strict outbound egress filtering policy allowing only standard ports (80/443) via authorized forward proxies; block direct outbound access to non-standard ports like TCP 2222.
Endpoint	Perform full memory and disk forensic imaging of workstation 10.11.28.101; scan with updated EDR signatures to locate and eradicate resident Dridex DLL loaders and persistence registry keys.
Accounts / Credentials	Initiate immediate password resets and Kerberos TGT invalidation for all user accounts that authenticated on 10.11.28.101 within the last 48 hours.
Active Directory	Audit Active Directory domain replication logs, Kerberos ticket-granting activity, and privileged group memberships to confirm no unauthorized privilege escalation occurred.
Recovery	Re-image workstation 10.11.28.101 from known-good golden baseline image prior to rejoining the corporate network; verify endpoint telemetry reporting in Security Onion.

6. CONCLUSION

Investigation of Phase 4 (OFA P4-07) conclusively determined that compromised workstation 10.11.28.101 initiated its first outbound TCP/2222 connection to external Dridex C2 server 86.159.48.25 at exactly **2025-10-08 09:01:59 UTC** (09:01:59.259 +00:00). The adversary leveraged non-standard port 2222 with TLSv1.2 encapsulation to bypass basic egress controls and establish a persistent interactive session. By identifying the exact timestamp and associated IOCs, the team successfully submitted the flag **CTK{2025-10-08 09:01:59 UTC}**, securing full challenge points (1000 Pts / 997 Pts) and laying the groundwork for threat mitigation.

7. EVIDENCE LIMITATIONS

1. TLS Payload Obfuscation: Because the TCP 2222 communication was wrapped in TLSv1.2 encryption without an inline SSL-decryption proxy, the specific plaintext shell commands and downloaded memory modules could not be extracted directly from PCAP data.

2. Host Endpoint Artifacts: The primary data source available was network telemetry (Zeek, Suricata, Security Onion). Host-based memory captures and Windows Event Logs are required to confirm the precise executing process PID and local user account identity.

8. APPENDICES

Appendix A — Investigation Queries

Query 1 (Security Onion Hunt — Zeek Connection Search):

```
destination.port:2222 AND event.dataset:"zeek.conn"
```

Query 2 (Security Onion Hunt — Filter by Destination IP & Port):

```
destination.ip:"86.159.48.25" AND destination.port:2222
```

Query 3 (Suricata JA3 Threat Hunt):

```
event.dataset:"suricata.alerts" AND rule.name:*Dridex*
```

Appendix B — Figures and Screenshots

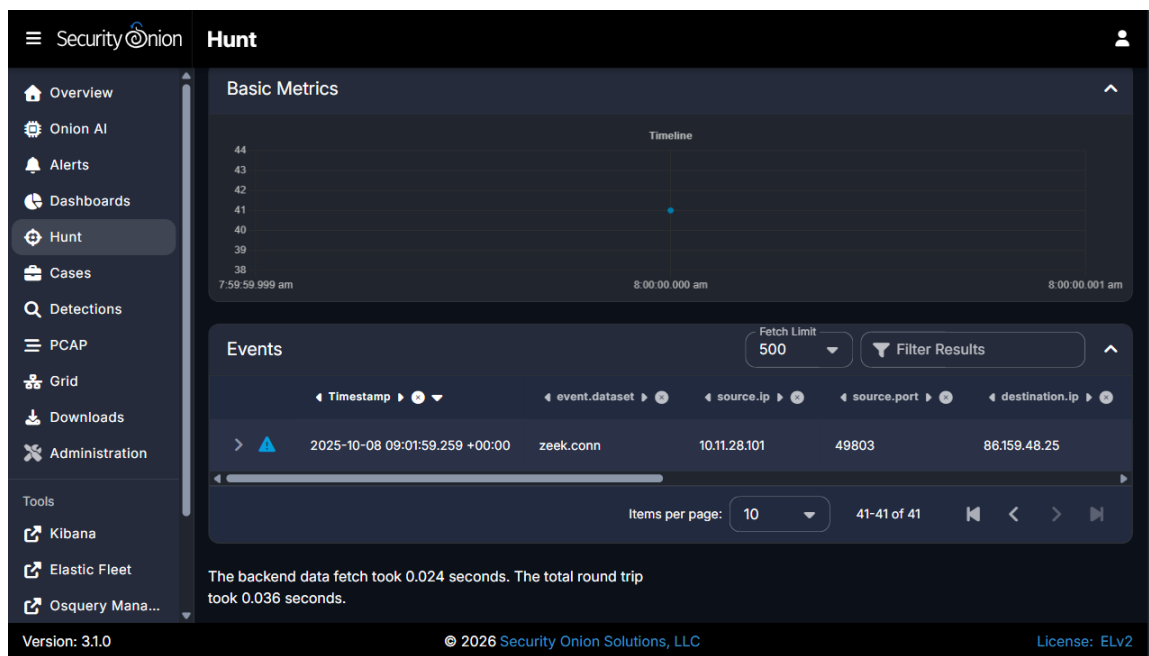


Figure 1: Security Onion Hunt query showing earliest TCP 2222 connection beginning at 2025-10-08 09:01:59.259 +00:00 from 10.11.28.101:49803 to 86.159.48.25:2222.

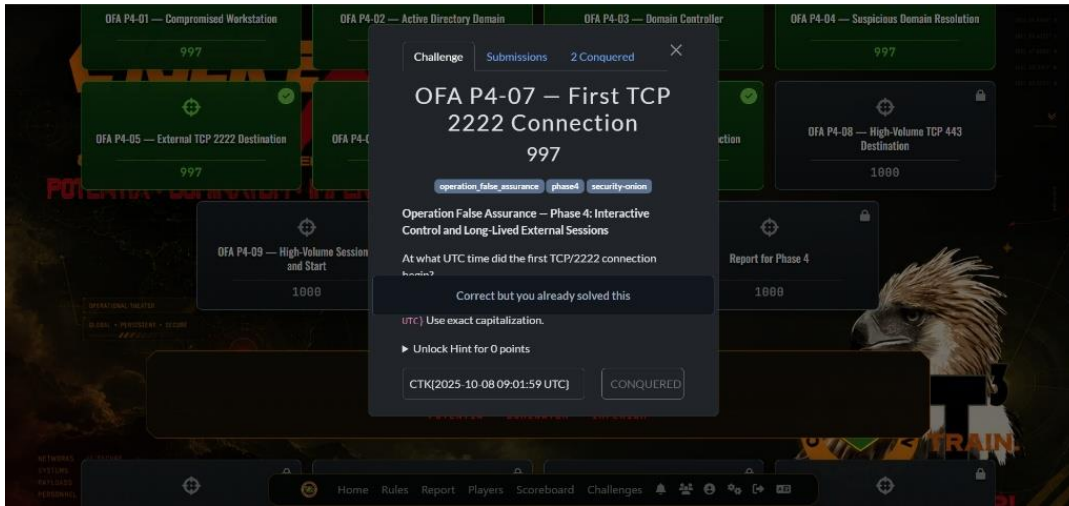


Figure 2: CyberEx Challenge Portal verification confirming challenge OFA P4-07 — First TCP 2222 Connection conquered with flag CTK{2025-10-08 09:01:59 UTC}.

Figure	Caption / Description
Figure 1	Security Onion Hunt UI displaying the earliest TCP 2222 connection timestamp (2025-10-08 09:01:59.259 +00:00) with source 10.11.28.101 and destination 86.159.48.25.
Figure 2	CyberEx challenge completion popup displaying 'OFA P4-07 — First TCP 2222 Connection' marked as CONQUERED with submitted flag CTK{2025-10-08 09:01:59 UTC}.

REPORT QUALITY REQUIREMENTS & SUBMISSION INSTRUCTIONS (5% — 50 Points)

- Clear and logical organization with professional typography and formatting.
- Correct technical terminology (NIDS, JA3, TLSv1.2, Zeek decoders, MITRE ATT&CK T1571/T1573.002).
- Accurate use of timestamps strictly in UTC (2025-10-08 09:01:59 UTC).
- High-resolution embedded screenshots with sequential figure numbers and forensic captions.
- Clear distinction between confirmed facts and analyst inference.